OPEN-SOURCE REVIEW REPORT

Package Analysis: Both Generated Operator Images

An open-source license and usage review of all packages and artifacts present in both KServe Operator container images (`v302` operator image and `v302-bundle` OLM bundle image), prepared for the Open-Source Review Board.

Project
KServe Raw Mode Operator

Operator Image
`docker.io/akashneha/kserve-raw-operator:v302`

Bundle Image
`docker.io/akashneha/kserve-raw-operator:v302-bundle`

Date
April 28, 2026

Analyzed with
Claude (Anthropic)

1 — Context: How These Packages Enter the Image

The KServe operator binary is compiled with **CGO_ENABLED=0** (a fully static Go binary) and packaged using `gcr.io/distroless/static:nonroot` as the runtime base image. The operator itself contains no Debian packaging; however, the distroless image is constructed by Google from a curated subset of Debian packages. `netbase` and `base-files` are pulled in as **transitive dependencies of the distroless build chain** and materialise as read-only configuration files inside the container filesystem.

Key point: No source code from either package is incorporated into the operator binary. No executable from either package runs inside the container. They exist solely as filesystem artifacts (e.g. `/etc/services`, `/etc/protocols`, `/etc/debian_version`).

🐳 1b — Images Generated by This Project

IMAGE	BASE	PURPOSE	CONTAINS OS PACKAGES?
`kserve-raw-operator:v302`	`gcr.io/distroless/static:nonroot`	Operator runtime — runs the Go controller manager binary	✓ Yes — `netbase`, `base-files` (Debian, via distroless)
`kserve-raw-operator:v302-bundle`	`scratch` (empty)	OLM bundle — carries YAML manifests consumed by OLM at install time	✗ None — zero OS packages

📦 2 — Package: `netbase`

netbase

Basic TCP/IP networking infrastructure — configuration data files only

GPL-2.0-only

PURPOSE	Provides networking configuration data files: `/etc/services`, `/etc/protocols`, `/etc/rpc`. These map well-known port numbers and protocol numbers to human-readable names.
VERSION (DISTROLESS)	6.4 (Debian Bookworm / debian12 variant)
LICENSE (SPDX)	**GPL-2.0-only** — GNU General Public License, version 2 only
COPYRIGHT HOLDERS	© 1994–1998 Peter Tobias · © 1998–2001 Anthony Towns · © 2002–2022 Marco d'Itri

SOURCE AVAILABILITY	Fully public: `https://packages.debian.org/stable/netbase`
MODIFIED BY PROJECT?	**No.** Used unmodified, exactly as distributed by Debian.
LINKED / COMPILED IN?	**No.** No code from netbase is compiled into the operator binary. It is a passive data file.
EXECUTABLE IN CONTAINER?	**No.** netbase contains no executables — it is purely configuration data.

🔍 **Review Board Assessment — netbase**

GPL-2.0-only is a strong copyleft license; however, copyleft obligations are triggered by *distribution of derived works* — i.e., modifying and distributing the GPL-licensed source code itself. Shipping an unmodified Debian package as a data file inside a container image is equivalent to distributing a pre-built Debian system: the operator is not a derivative work of netbase. No source-code disclosure of the operator is required. The only obligation is attribution (referencing upstream Debian as the source), which the distroless project fulfils by embedding the `/usr/share/doc/netbase/copyright` file inside every image layer.

📦 3 — Package: `base-files`

`base-files`

Debian filesystem skeleton — directory structure and OS metadata files

GPL-2.0-or-later

PURPOSE	Provides essential directory structure and OS identification files: `/etc/debian_version`, `/usr/share/common-licenses/`, `/etc/issue`, `/etc/motd`, and base directory skeleton.
LICENSE (SPDX)	**GPL-2.0-or-later** — GNU General Public License, version 2 or any later version
COPYRIGHT HOLDERS	© Software in the Public Interest, Inc. (the Debian non-profit organisation)
SOURCE AVAILABILITY	Fully public: `https://packages.debian.org/stable/base-`

	`files`
MODIFIED BY PROJECT?	**No.** Used unmodified, exactly as distributed by Debian.
LINKED / COMPILED IN?	**No.** No code from base-files is compiled into the operator binary.
EXECUTABLE IN CONTAINER?	**No.** base-files contains no executables — it is directory structure and text files only.

🔍 **Review Board Assessment — base-files**

GPL-2.0-or-later with the same reasoning as netbase. The `-or-later` clause is more permissive than `-only` as it allows future GPL versions. base-files is a standard infrastructure package shipped with every Debian-based container image worldwide — its presence is universal and its compliance posture is well-established. No operator source disclosure is required. Attribution is embedded in the image via the standard Debian copyright mechanism.

📦 3b — Image: `kserve-raw-operator:v302-bundle` (OLM Bundle)

OLM Bundle Image

FROM scratch — carries only generated YAML manifests for the Operator Lifecycle Manager

No Third-Party Packages

BASE IMAGE	`FROM scratch` — an absolutely empty Docker image. Contains no OS, no libc, no shell, no filesystem beyond what is explicitly COPY'd.
CONTENTS	`/manifests/` — CRD YAML, ClusterServiceVersion YAML, RBAC YAMLs `/metadata/` — OLM annotations (`annotations.yaml`) `/tests/scorecard/` — Scorecard test configuration All files are generated by `operator-sdk` and `controller-gen` from project source.
THIRD-PARTY OS PACKAGES	**None.** `scratch` provides zero packages. Every file in this image originates from the project's own code generation pipeline.

EXECUTABLES	**None.** The bundle image contains no runnable binaries. It is consumed by the OLM operator-sdk toolchain as a pure data container.
TOOLCHAIN USED TO BUILD IT	`operator-sdk v1.42.2` (Apache-2.0) — used to *generate* the bundle; not shipped inside the image.
OLM FRAMEWORK	`Operator Lifecycle Manager` (Apache-2.0) — *consumes* the bundle at deploy time; not embedded in the image.

🔍 **Review Board Assessment — OLM Bundle Image**

Zero open-source license obligations arise from the bundle image itself. Because the base is `scratch`, there are no third-party packages to attribute. The only OSS components relevant to this image are the *toolchain* that generates it (`operator-sdk`, Apache-2.0) and the *framework* that consumes it (OLM, Apache-2.0) — both permissive licenses with no copyleft obligations. The YAML manifests inside the image are 100% project-owned artifacts generated from your own Go type definitions.

✅ 4 — Consolidated Review Summary

This table covers both generated images. The bundle image has no third-party packages; all OSS obligations come from the operator image's distroless base.

REVIEW QUESTION	NETBASE (operator image)	BASE-FILES (operator image)	BUNDLE IMAGE (v302-bundle)
Third-party packages present?	✓ Yes — GPL-2.0-only	✓ Yes — GPL-2.0-or-later	✗ None (FROM scratch)
Modified by the project?	✗ Not modified	✗ Not modified	N/A
Compiled into any binary?	✗ No — data files only	✗ No — data files only	N/A
Executes inside the container?	✗ No executables	✗ No executables	✗ No executables at all

REVIEW QUESTION	NETBASE (operator image)	BASE-FILES (operator image)	BUNDLE IMAGE (v302-bundle)
Copyleft propagates to operator?	✗ No — not a derivative work	✗ No — not a derivative work	N/A
Must operator source be disclosed?	✗ Not required	✗ Not required	✗ Not required
Attribution required?	✓ Yes — embedded by distroless	✓ Yes — embedded by distroless	✗ None needed
Source publicly available?	✓ packages.debian.org	✓ packages.debian.org	N/A — 100% project-owned

📋 5 — Compliance Obligations

✓ **Acknowledge presence in SBOM / release notes.** Both packages must be listed in any Software Bill of Materials (SBOM) generated for each release. The distroless project's own SBOM tooling (compatible with SPDX and CycloneDX) can be used.

✓ **Point to upstream source on request.** If a downstream customer or partner asks for source code, direct them to `https://packages.debian.org/`. You are not required to host copies yourself.

✗ **You do NOT need to open-source your operator.** GPL copyleft does not extend to applications that merely run in a container alongside GPL-licensed config files.

✗ **You do NOT need to ship the GPL license text yourself.** The distroless image already embeds `/usr/share/common-licenses/GPL-2` and per-package copyright files inside the image layers, satisfying the attribution requirement.

💡 6 — Recommendations for Future Releases

🔒 Pin Image by Digest

Replace `:nonroot` tag with a pinned SHA-256 digest in the Dockerfile to

📄 Generate SBOM per Release

Run `syft` or `docker sbom` on the final operator image as part of the CI

prevent silent base-image updates that could introduce new packages between releases.

pipeline and attach the SPDX/CycloneDX file as a release artifact.

🔍 Use Trivy / Grype for CVE Scanning

Run vulnerability scanning on the image after each build to detect any CVEs in the distroless layer packages, including `netbase` and `base-files`.

📬 Establish a Source-Request Process

Document an internal process for responding to GPL source-code requests from customers, pointing to `packages.debian.org` as the canonical upstream.

© 2026 Internal Document — Confidential. For Open-Source Review Board Use.

Analyzed with **Claude · Anthropic** | April 28, 2026